

Cybersecurity

Enterprise Security Management

Lesson 12.3



Learning Objectives

By the end of today's lesson, you will be able to:

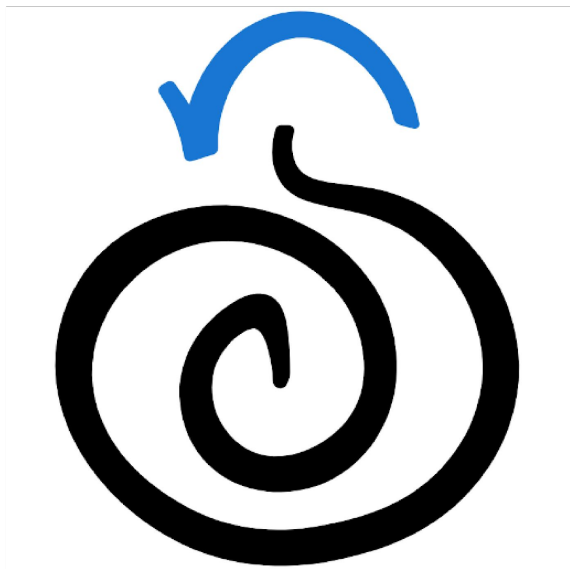
- 1 Analyze indicators of attack for persistent threats.
- 2 Use enterprise security management (ESM) to expand an investigation.
- 3 Use OSSEC endpoint reporting agents as part of a host-based IDS alert system.
- 4 Investigate threats using various analysis tools.
- 5 Escalate alerts to senior incident handlers.



Welcome



Security Onion Setup



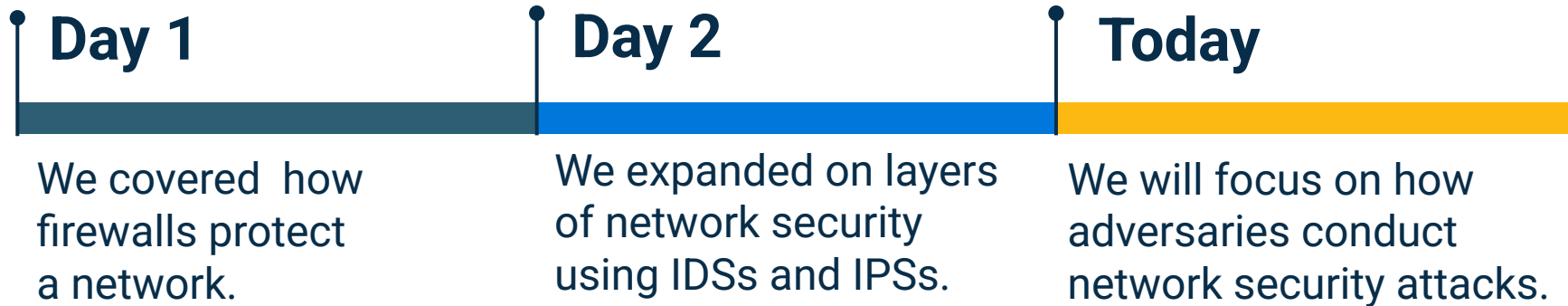
Before we get started, we need to launch an instance of **Security Onion**.

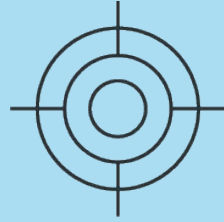
This will generate alert data that we'll use to complete the labs.



Let's Recap

Network Security Recap





C2 Alert **Beacon** Setup



In the next activity,
you will apply your knowledge
of NSM to an attack that
targets a **command and
control (C2)** server.

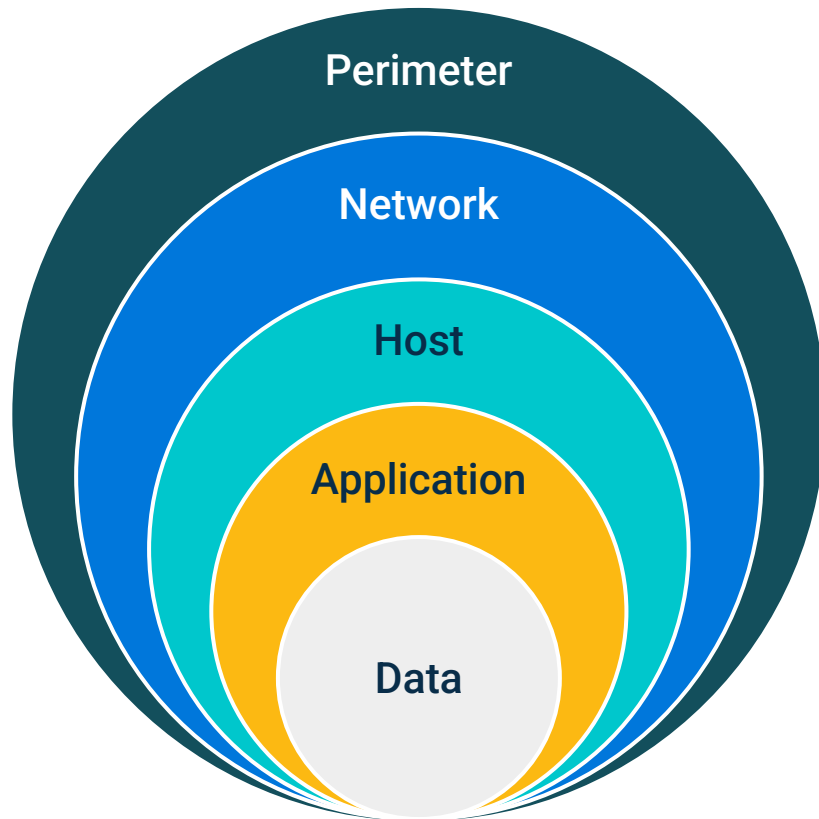


C2 Alert Beacon

Network security monitoring (NSM)

NSM plays a critical role in implementing an in-depth defense approach.

NSM adds an additional layer of protection when an adversary **bypasses** defenses.





Command and Control (C2)

C2 servers are used to create a specific type of alert for attacks.

- Infected hosts make **callbacks** to C2 servers, giving cybercriminals access in and out of the network.
- Keep alive beacons activate a specific alert.

Q   Last 50 days  REFRESH 

Click the clock icon to change to absolute time

Fetch Limit 500   c2

	Count	rule.name 	event.module 	event.severity_label  
 	9	ET MALWARE Zbot POST Request to C2	suricata	high

Rows per page: 50  1-1 of 1  



Command and Control (C2)

Suricata rules

- Sometimes, writers of Suricata rules will put additional information in their rule message to help network defenders.
- With this information, network defenders can form mitigation strategies.

log.offset

183766

message

```
{ "timestamp": "2023-12-19T21:58:23.993561+0000", "flow_id": "2008945077574714", "in_iface": "bond0", "event_type": "alert", "src_ip": "192.168.3.3", "id": "2019141", "rev": 5, "signature": "ET MALWARE Zbot POST Request to C2", "category": "Malware Command and Control Activity Detected", "severity": "alert", "action": "pass", "flow": "established,to_server", "http.method": "POST", "http.uri": ".php", "http.header": "Accept/3a 20l", "content": "Accept/0d 0alUser-Agent/0d 0alHost/0d 0alContent-Length/0d 0al"; depth:44; content: "Accept-"; content: "Content-Type/0d 0al"; content: "0_11_03;");", "files": [{"filename": "/back11/stat1.php", "gaps": false, "state": "CLOSED", "stored": false, "size": 270, "tx_id": 0}], "app_proto": "http", "directon": "Keep-Alive\\nPragma: no-cache\\n\\n".C..... .u.g.j.2:Bt~..\\ ">.....5.m...d.v...i.j.f...#}09..b).,\\rVH...Q..?~...c.>~eJ!.....e[3.....ex.8....CjvHwFZAQKAFA79IruDwtmLVAQ/GDtUgAAAAAAAAAAAA", "packet_info": {"linktype": 1}}
```

metadata.beat

filebeat



Activity

C2 beacon

In this activity, you will work in groups and play the role of an SOC analyst for the California DMV.

- Your organization has just experienced another attack that Snort has identified as an emerging threat: a C2 beacon acknowledgement attack.
- You will establish an attacker profile that includes the TTPs used by the adversary and document all of your findings.

Suggested Time
20 minutes



Time's Up!
Let's review



Questions?





Enterprise Security Management (EMS) and Monitoring



Now that we've learned about the benefits of using firewalls and NSM, we'll cover the more all-encompassing **enterprise security monitoring (ESM)**, which includes endpoint telemetry.

OSSEC

Firewalls and NSM cannot access encrypted traffic. In most cases, malware will be transmitted from attacker to victim in an encrypted state to hide its presence and intent. This also serves as a method of obfuscation to bypass IDS detection engines.

01

Malware cannot activate in the encrypted state.

02

It must be decrypted before it can launch.

03

This can only happen after it's been installed on the victim's machine.



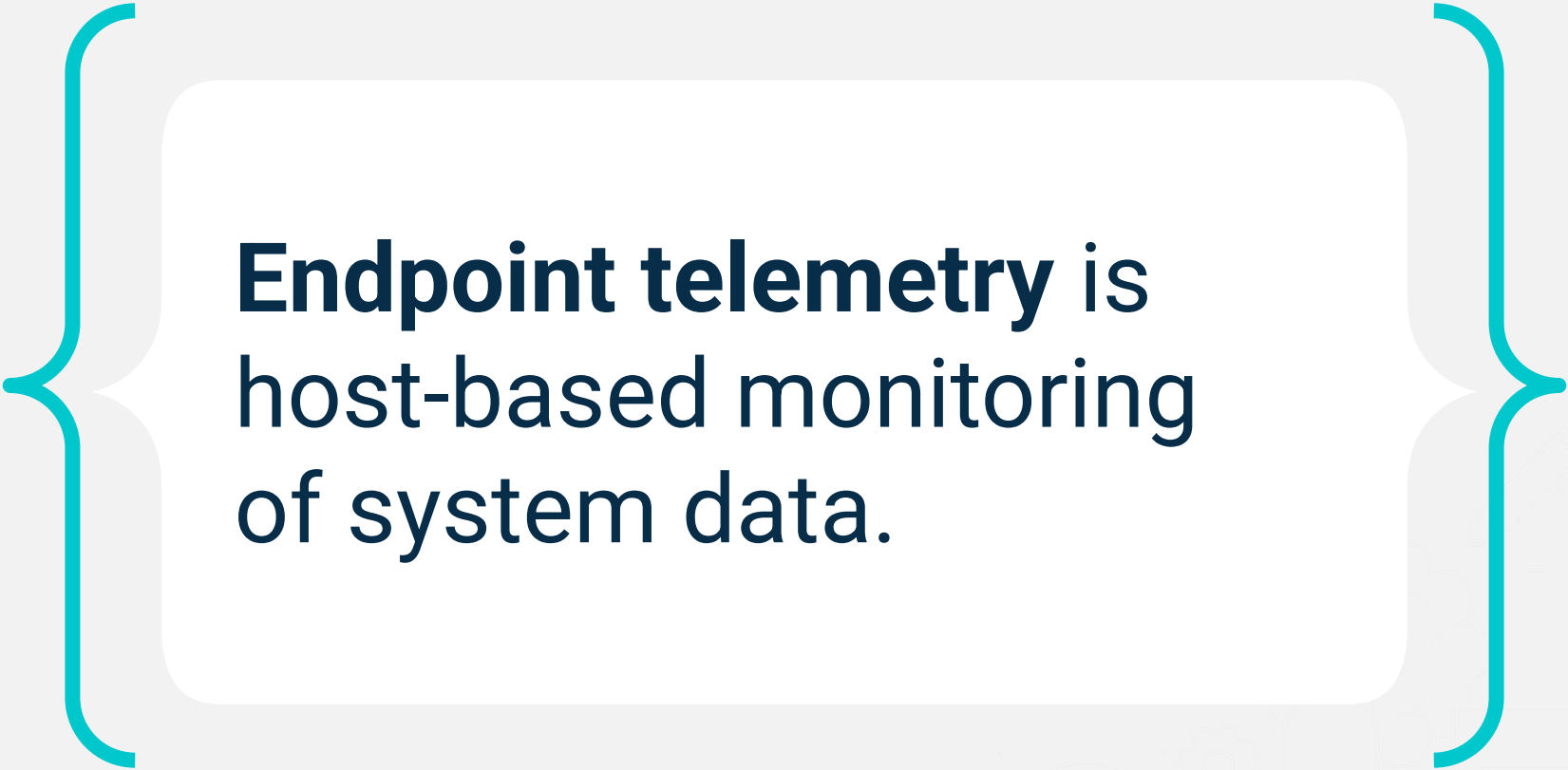
This is where ESM and, more specifically, endpoint telemetry become relevant.

OSSEC

ESMs use OSSEC to provide visibility at the host level.

- OSSEC is the industry's most widely used host-based IDS (HIDS).
- It has many configuration options and can be tailored to the needs of any organization.



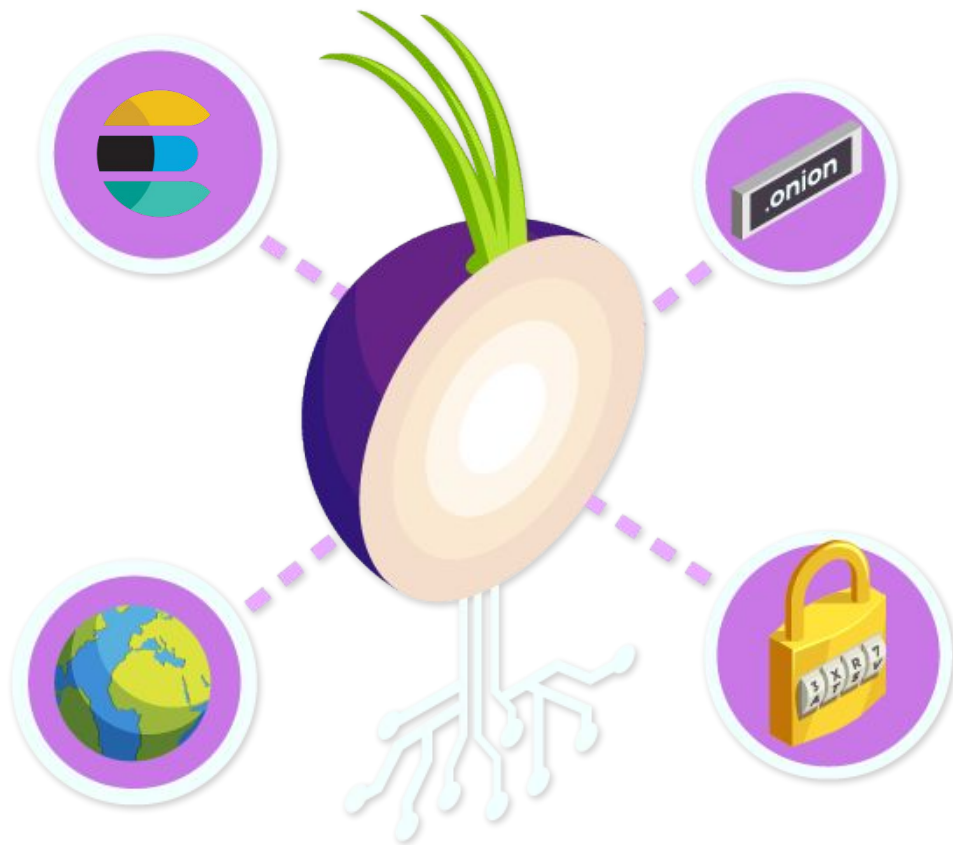


Endpoint telemetry is
host-based monitoring
of system data.



OSSEC Agents are Deployed to Hosts and Collect Syslog Data

- This data generates alerts that are sent to the centralized server Security Onion.
- Security administrators can then use Security Onion to form a detailed understanding of the situation and reconstruct a crime.



Elastic Stack

OSSEC monitors syslog data, but security admins use three other important tools to fully analyze packet captures:



elasticsearch



logstash



kibana

Elastic Stack

These tools are collectively known as Elastic (ELK) Stack, the engine that operates within Security Onion.

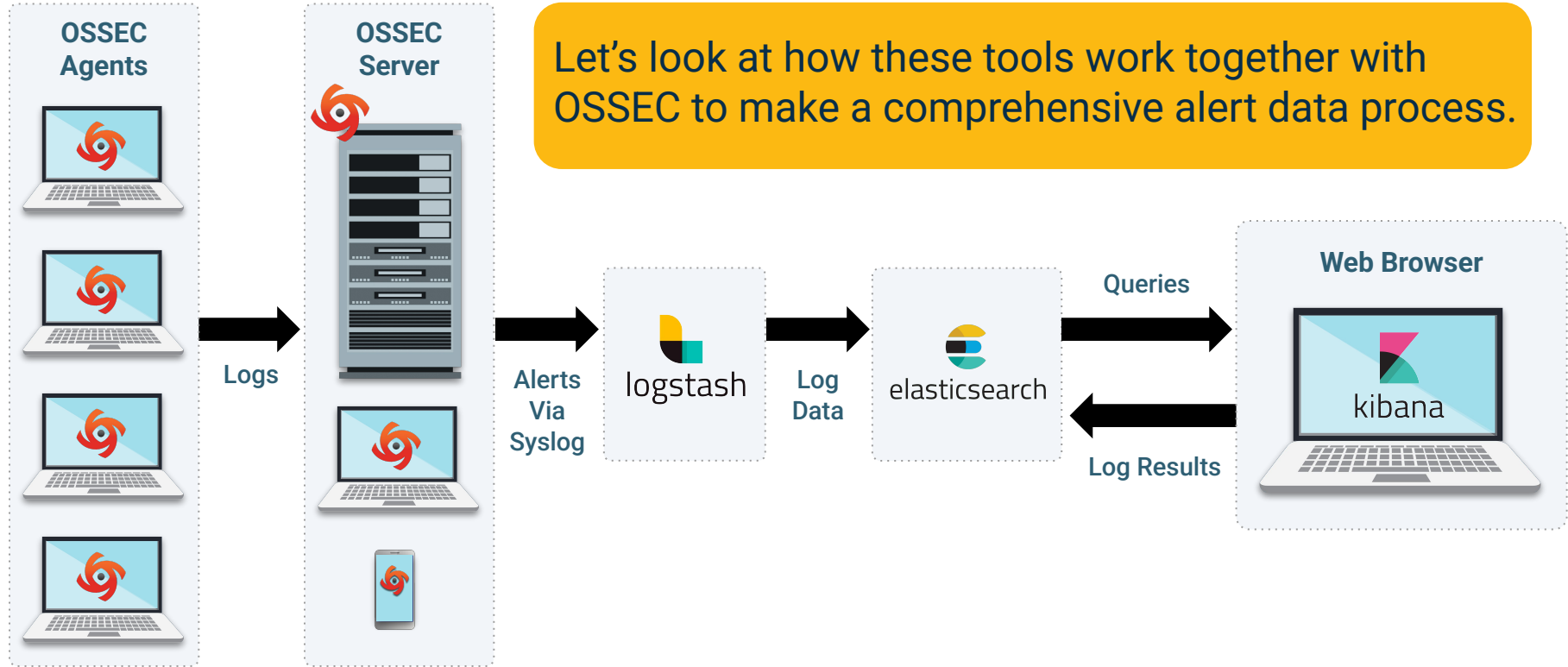


- Heart of the Elastic Stack
- Distributed, restful search and analytics engine
- Helps security administrators locate the expected and uncover the unexpected

- Open source
- Server-side data-processing pipeline
- Ingests data
- Transforms and sends data to designated log file

- Browser-based visualization interface
- Uses data points from the Elastic Stack

Elastic Stack Overview



Elastic Stack Overview

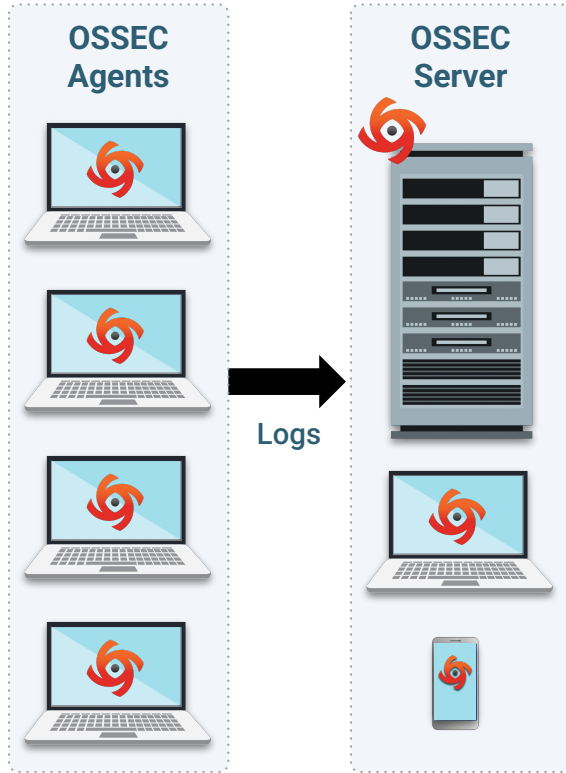
OSSEC Agents



01

OSSEC agents generate an alert.

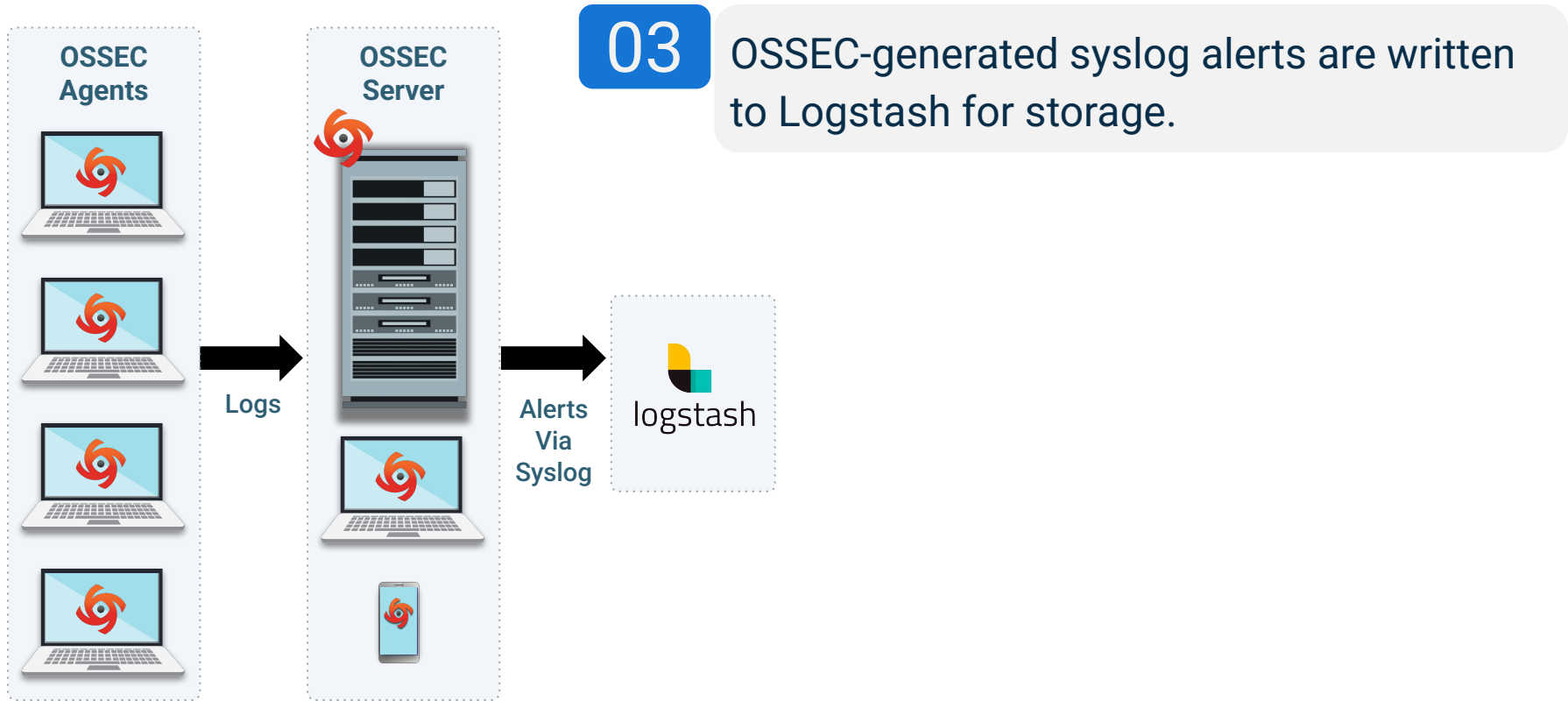
Elastic Stack Overview



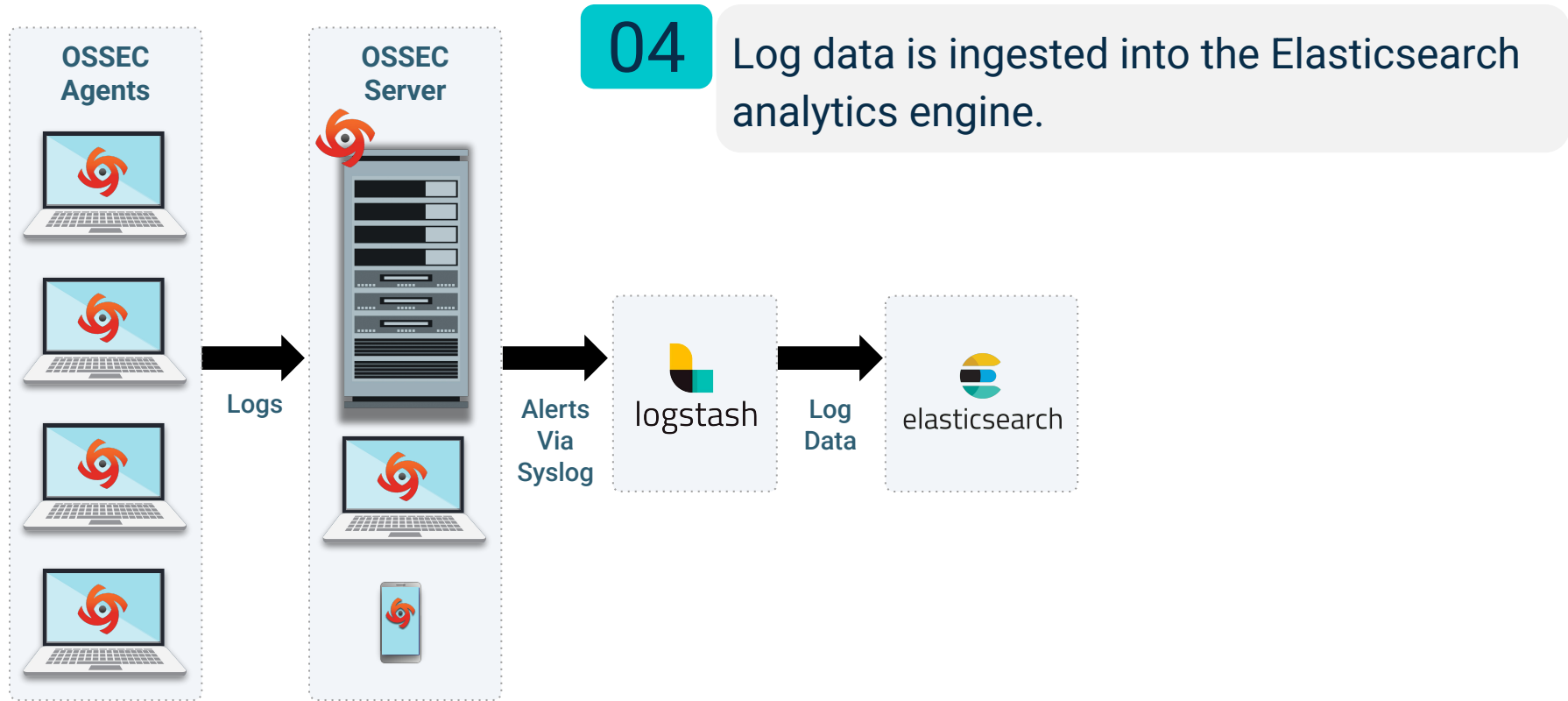
02

OSSEC sends alert data gathered from syslog to the Security Onion OSSEC server.

Elastic Stack Overview



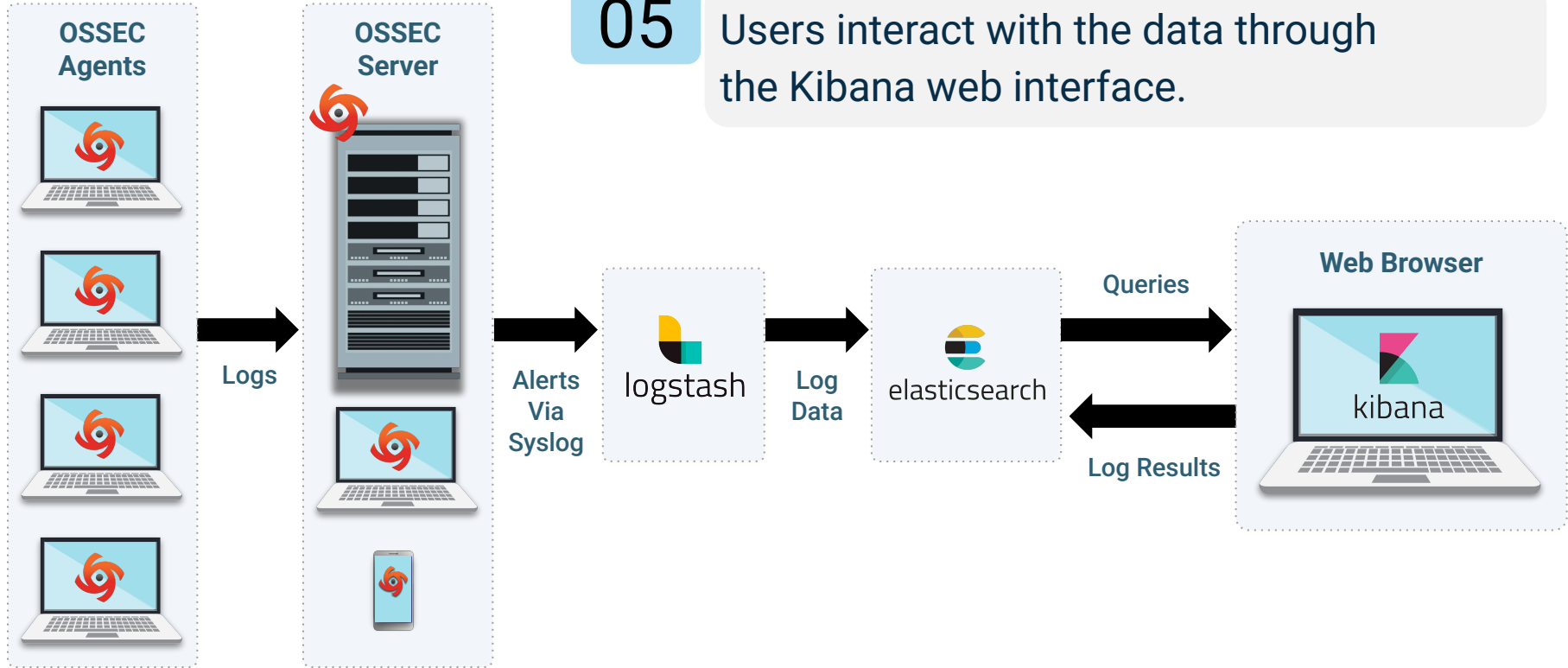
Elastic Stack Overview



Elastic Stack Overview

05

Users interact with the data through the Kibana web interface.



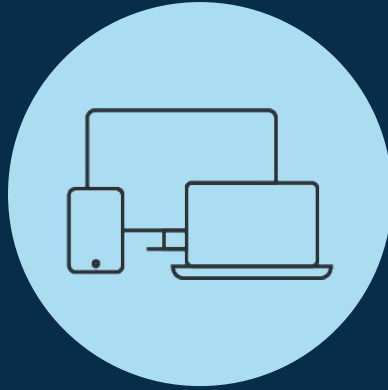


Demonstration Scenario

We will use several tools that work together during an investigation within Security Onion.

- We will also focus on the process of escalation within an SOC.
- We'll continue our investigation by looking for more **Zbot** traffic.





Instructor Demonstration

Investigation, Analysis, and Escalation

Demonstration Recap

In this demonstration, we conducted investigations using various threat hunting techniques. We focused on a few of the many ways to start an investigation.

ESM includes endpoint telemetry, host-based monitoring of system data that uses OSSEC collection agents to gather syslog data.

To investigate network-based IDS alerts, security administrators must use ESM, which includes visibility into endpoint OSSEC agents.

IDS alerts are snapshots in time. They raise questions that need answers. With the use of Security Onion, security admins can use PCAPs to reconstruct a crime.



Activity

Investigation, analysis, and escalation

In this activity, you will continue your role as an SOC analyst for the California DMV.

- You will use Security Onion and Kibana to investigate, analyze, and escalate indicators of attack.

Suggested Time
20 minutes



Time's Up!
Let's review

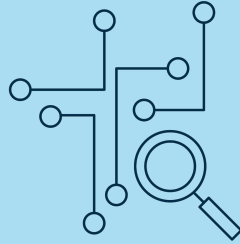


Questions?





Break
15 mins



Threat Hunting



Threat intelligence
is important at every level
of government and public
sector organizations where
it's used to determine
acceptable risk and develop
security controls that
inform budgets.



Threat Hunting

Malicious actors

01

Hacktivist



02

Criminal Hackers



03

Cyber Espionage Campaigns



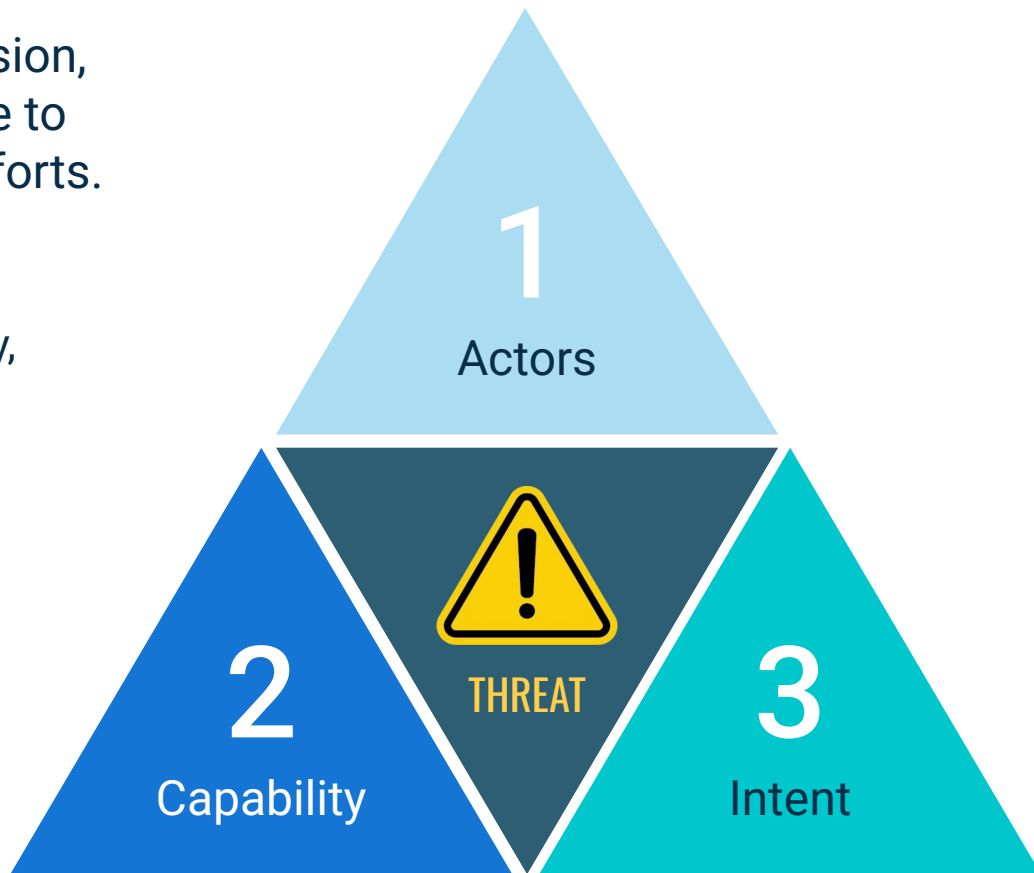


Computer and incident response teams (CIRTs) are responsible for establishing **threat intelligence cards**, which document the TTPs used by an adversary to infiltrate a network.

Threat Intelligence Card

When handling a large-scale intrusion, incident responders often struggle to organize intelligence-gathering efforts.

- Threat intelligence cards are shared among the cyberdefense community, allowing organizations to benefit from the lessons learned by others.
- The triad of actors, capability, and intent informs situationally aware decision-making, enhanced network defense operations, and effective tactical assessments.





Threat Hunting

Cyber kill chain

01

Reconnaissance

02

Weaponization

03

Delivery

04

Exploitation

05

Installation

06

Command and control (C2)

07

Actions on objectives



Threat Hunting

Cyber kill chain

Advantages	Examples
Reconnaissance	Information-gathering stage against targeted victim. Information sources include: • DNS registration websites • LinkedIn • Facebook • Twitter



Threat Hunting

Cyber kill chain

Advantages	Examples
Weaponization	After collecting information regarding infrastructure and employees, adversaries have the capability to establish attack vectors and technical profiles of targets such as: • Logical and administrative security controls • Infil/exfil points



Threat Hunting

Cyber kill chain

Advantages	Examples
Delivery	The delivery of the weaponized payload via: • Email • Website • USB



Threat Hunting

Cyber kill chain

Advantages	Examples
Exploitation	Actively compromise adversary's applications and servers while averting the physical, logical, and administrative controls. Exploiting employees through social engineering. This stage prepares for escalation during the installation phase.



Threat Hunting

Cyber Kill Chain

Advantages	Examples
Installation	A.k.a. the persistence preparation phase. Activities include malicious software installation, backdoor implants, and persistence mechanisms such as cron jobs, AutoRun keys, services, log file deletion, and timestamp manipulation.



Threat Hunting

Cyber Kill Chain

Advantages	Examples
Command and Control (C2)	A command channel, most typically Internet Relay Chat (IRC), used for remote control of a victim's computer.



Threat Hunting

Cyber Kill Chain

Advantages	Examples
Actions on Objectives	After achieving the equivalent of “Hands on Keyboard” access to a victim's systems, adversaries are now able to action their objectives.



Activity

Threat hunting: cyber threat intelligence

In this activity, you will continue your role as an SOC analyst for the California DMV.

- You've decided to include threat hunting as part of your defense strategy. You assembled a team of highly motivated security professionals.
- This activity only requires hunting a single threat, as time is limited.

Suggested Time
35 minutes



Time's Up!
Let's review



Questions?





Next Class

HTTP with sessions and cookies



Thank You